

כל מספר בדוח הזה נמדד מול המערכת החיה. מה שלא נמדד — כתוב במפורש שלא נמדד.

2

פערים חוסמים

שניהם לחיצת כפתור

0

טבלאות פתוחות לאינטרנט

היו חמש הבוקר

36,000

ילדים משחקים בו-זמנית

רצפה. התקרה היא Supabase

איפה זה עומד

עד המשחקים — שהוא רוב התנועה — בשל ונמדד. מסד הנתונים נקי: כל חמש הטבלאות שהיו פתוחות לכל אדם באינטרנט סגורות, וחור המנויים שאיפשר לכל בעל חשבון Google לתת לעצמו מנוי בתשלום — סגור ומאומת. צד הטיטור תוקן בקוד אבל טרם עלה לאוויר. שני דברים חוסמים יציאה לפרודקשן, ואף אחד מהם אינו כתיבת קוד.

Cloudflare אבטחה ב-

אין CSP מול iakids.app; במראה זה כבר חי ונקי

deploy עם APP_ENV=prod backends-לשני ה

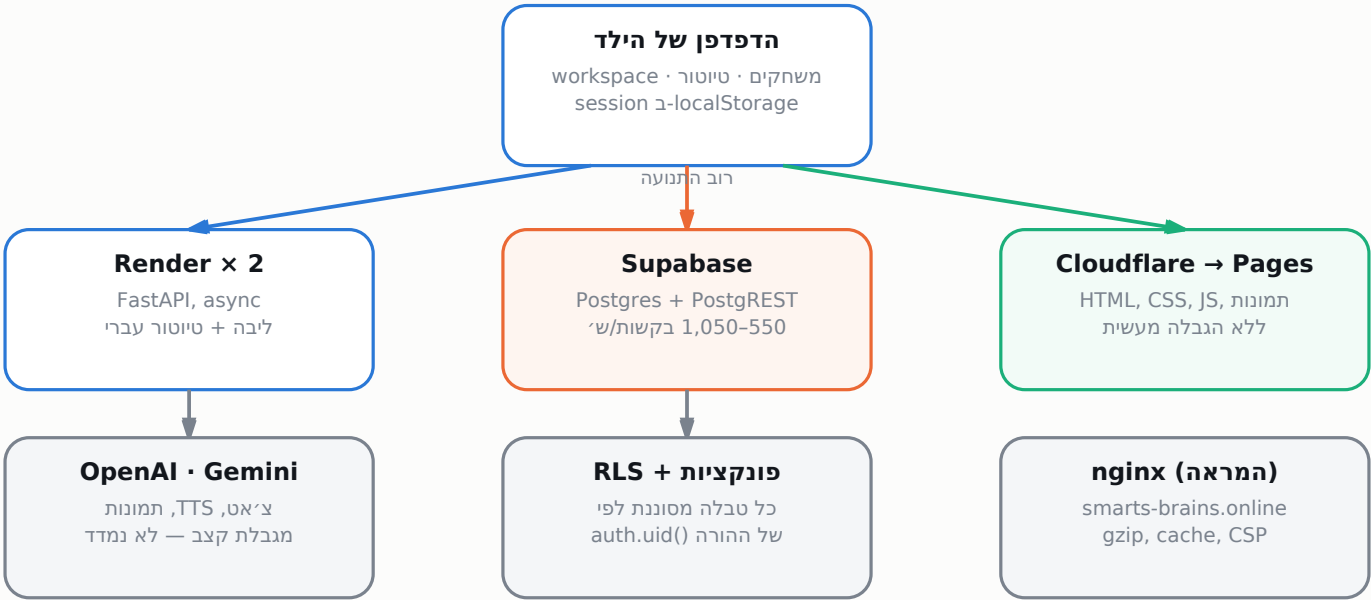
מכסה · CORS מ-localhost · async · פתוח Swagger

מה נסגר היום

מה	מה היה	מצב
חמש טבלאות פתוחות	מפתחות תשובות למבחנים, התקדמות ילדים, תוכן שיעורים	נסגר ואומת
מנוי בתשלום מהדפדפן	חשבון חינמי הכניס plan=annual עד 2099 — התקבל	נסגר ואומת
בנק השאלות	106,096 שאלות עם התשובות, לכל מבקר	נסגר ואומת
מכסת ההודעות	גם למשלמים, ומרוץ בין בקשות מקבילות LIMIT=20	נסגר ואומת
14 קריאות לסשן	תשובה אחת = קריאה אחת למסד	4 קריאות
שתי מערכות זהות	הורה שהגיע מה-workspace התבקש להתחבר שוב	זהות אחת

"נסגר ואומת" = תוקן, והתיקון נבדק מול המערכת החיה עם חשבון זמני שנמחק אחריו.

שני דברים חשוב להבין כאן. הראשון: רוב מה שילד עושה לא נוגע בשרת שלנו בכלל — הדפים סטטיים ויושבים ב-Cloudflare, והמשחק מדבר ישירות מול Supabase. השני: Render נמצא רק במסלול הטיטור, ושם הזמן הולך למודל, לא לקוד שלנו.



רכיב	מה הוא מריץ	מה מגביל אותו	מידה
Cloudflare + Pages	כל הדפים, ה-CSS וה-JS	אין מעשית	—
Supabase	המסד, ה-RLS, האימות, האחסון	של המסד CPU	נמדד
ליבה — Render	ציאת ספרדי, webhook של תשלומים	96 חוטים, 30/דקה	לא נמדד
טיטור — Render	19 נתיבים, שיעורים, TTS, שיעורי בית	המודל	לא נמדד
nginx (המראה)	עותק של האתר, לא מאחורי Cloudflare	המכונה הזו, 2 ליבות	נמדד

המראה smarts-brains.online היא nginx על שרת האפליקציה, לא Cloudflare — ולכן דחיסה, קאשינג, כותרות אבטחה ומגבלת קצב מוגדרים שם בנפרד. הם הוגדרו ונבדקו.

כמה משתמשים המערכת מחזיקה

נמדד ב-wrk, המחולל מתחת ל-50% CPU

הבדיקות הקודמות מדדו את מכונת הבדיקה ולא את השירות. עם כלי זול בהרבה לכל בקשה, המחולל יושב מתחת לחצי עומס בזמן שהמספרים מטפסים — ואלה המספרים של Supabase עצמה.



מעבר לנקודות האלה התפוקה מפסיקה לעלות וההשהיה מוכפלת — שרת רווי. ההשהיה עצמה היא 100 מילישניות בין אם השרת בטל ובין אם הוא ב-600 בקשות לשנייה: זה זמן ההלוך-חזור לאזור, לא עבודה. השאילתה של בנק השאלות עולה כמו קריאת שורה בודדת. אין שם מה לכוון.

מכאן למספר ילדים

איזור	מה זה עולה	מה מגביל	בו-זמנית	מקור
משחקים	4 קריאות לסשן	Supabase	36,000	נמדד
משחקים — סשן מהיר	4 קריאות ב-100 ש"י	Supabase	15,000	נגזר
לפני תיבת היוצא	14 קריאות לסשן	Supabase	10,300	היסטורי
דפים סטטיים	בלבד Cloudflare	אין מעשית	ללא הגבלה	—
צ'אט הטיטור	Render → OpenAI	המודל	לא נמדד	חסר
יצירת שיעור	רקע בתוך תהליך הבקשה	מת ב-deploy	שביר	ידוע
הרשמה והתחברות	Supabase Auth	לא נמדד	לא נמדד	חסר

סשן של עשר שאלות עולה היום 4 קריאות — היה 14 לפני שהתשובות נאספות בדפדפן ונשלחות יחד. פרוס על ארבע דקות זה 0.017 קריאות לשנייה לילד, ו-600 קריאות לשנייה מתחלקות ל-36,000 ילדים. ילד שרץ מהר יותר עולה יותר: 15,000 במקרה הצפוף.

שני המספרים הם רצפה: הם נמדדו ממכונה אחת. התקרה האמיתית גבוהה יותר בדיוק כמו שמחולל גדול יותר היה מוצא.

#	מה	למה זה משנה	איפה	דחיפות
1	backends-לשני ה deploy	כל התיקונים בריפוי, אף אחד לא באוויר	Render	חוסם
2	כותרות אבטחה	אין CSP מול iakids.app	Cloudflare	חוסם
3	מפתחות LemonSqueezy	ריקים גם ב-env.prod — אין אימות webhook	env.prod	גבוה
4	מכסה לפני קריאת מודל	לציאת יש; ל-TTS ולתמונות אין	קוד	גבוה
5	תור לעבודה הכבדה	אודיו ותמונות מתים בכל deploy	קוד	גבוה
6	אין ניטור שגיאות	שום דבר לא מדווח כשמשהו נשבר	קוד	בינוני
7	PKCE	URL-של ה token-עובר ב	63 דפים	בינוני
8	אין בדיקות למשחקים	100 משחקים, אפס בדיקות אוטומטיות	קוד	בינוני

שני החוסמים, בפירוט

- 1ה-deploy נושא: סגירת Swagger, הוצאת localhost מ-CORS, הפסקת הדפסת דברי ילדים ללוגים, הטייטור ב-async, מכסת ההודעות החדשה, ונתיב בריאות לטייטור. חייב ובדיקת הבריאות. deploy-נשאר פתוח גם אחרי ה Swagger בלעדיו — APP_ENV=prod של Render צריכה להצביע על / בשני השירותים.
- 2ה-session של Supabase יושב ב-localStorage ב-63 דפים, כך שכל XSS הוא השתלטות מלאה על החשבון. GitHub Pages לא יכול לשלוח כותרות; Cloudflare כן. הנוסח המדויק כבר חי ונבדק במראה — 0 סירובים ב-8 דפים, אחרי שתי תקלות שהבדיקה תפסה.

רשימת יציאה לאוויר

- ☒ על חמש הטבלאות — הודבק ואומת מול המערכת החיה RLS
- ☒ מכסת הודעות אטומית לפי תוכנית — הודבקה ואומתה
- ☒ תיבת יוצא לתשובות — קריאה אחת במקום עשר
- ☒ מדינה ואזור זמן לכל חשבון
- ☒ כותרות אבטחה ו-CSP — חיים ונקיים במראה
- ☒ נתיב בריאות לטייטור — נמצא בהרצה מקומית לפני ה-deploy
- ☐ deploy ל-iakids-backend ול-iakids-ai-tutor-he
- ☐ / על health check בשני השירותים, ו APP_ENV=prod
- ☐ Cloudflare ב-iakids.app מול HSTS ו-CSP
- ☐ מגבלת קצב על */games ב-Cloudflare
- ☐ LEMON_API_KEY ו-LEMON_WEBHOOK_SECRET
- ☐ בדיקה חוזרת: tools/security_check.py מחזיר אפס

כל שורה מסומנת נבדקה מול המערכת החיה או בהרצה מקומית, לא רק נכתבה.

פתוחים

הבאג	מה קורה	חומרה
ריק <code>lemon_order_id</code>	לשני המנויים בתשלום אין הזמנה — המסד לא מסכים עם LemonSqueezy	גבוה
הדשבורד האנגלי מת	מפתח ה-chance בקובץ קטוע. הדף מעולם לא עבד	בינוני
ריקים <code>mode</code> ו- <code>device_type</code>	בכל 113 שורות <code>tutor_sessions</code> — אף אחד לא ממלא אותן	בינוני
לא קיימת <code>game_wins</code>	כותב לטבלה שאין ובולע את השגיאה IAKidsCloud	בינוני
6 קריאות רצופות	מחכה לכל אחת, והן בלתי תלויות <code>get_or_generate_unit_lesson</code>	בינוני
וידאו חסר בדף הבית	ריקה <code>assets/videos</code> מחזיר 404; התיקיה <code>iakids-demo.mp4</code>	נמוך
<code>parent-dashboard/index.com</code>	סיומת שגויה — שום דבר לא מגיש את הקובץ	נמוך

נסגרו היום

- a נפלה בכל קריאה — משתנה הלולאה וכינוי תת-שאלתה נקראו שניהם `game_record_answers`
 - לטיוטור לא היה נתיב שמחזיר 200 בלי `Render` — `token` היה מאתחל אותו בלולאה
 - ובפאנל ההורים היה ריבוע ריק `workspace`-כל אייקון ב: `CSP`-נחסם ב `Font Awesome`
 - כפתור הבית במשחק הציג להורה מחובר מסך התחברות
 - המשחקים הריצו זהות שנייה (`Firebase`) לצד ה-`Supabase` של האתר
 - המראה הגישה JS ו-CSS בלי דחיסה — `game-sdk.js` ל-96KB — ובלי קאשינג
 - דוק הכפתורים ב-`workspace` שמר שש עמודות אחרי שהוסתרו שניים
 - שם המשתמש וטבלאות האלופים היו לבן-על-לבן בערכה הכהה
- כולם אומתו: הרצה מקומית, דפדפן אמיתי, או בדיקה מול המערכת החיה.

הסדר כאן הוא לפי יחס תועלת-למאמץ, לא לפי גודל. שלושת הראשונים הם דקות.

#	מה	מה זה נותן	מאמץ	סוג
1	deploy + APP_ENV=prod	סוגר 6 מ-12 ממצאי האבטחה, ומשחרר את ה-async	דקות	מייד
2	CSP ב-Cloudflare	סוגר את 6 הנותרים; XSS מפסיק להיות השתלטות	דקות	מייד
3	שדרוג compute ב-Supabase	התקרה היא CPU של המסד; כל צעד מכפיל	דקות	פי 2
4	מכסה יומית לפני TTS ותמונות	היום חשבון גנוב יכול לשרוף תקציב מודל	שעות	הגנה
5	תור לעבודה הכבדה	אודיו ותמונות שורדים deploy, ולא גוזלים CPU מבקשות	יום	יציבות
6	ניטור שגיאות	לדעת שמהו נשבר לפני שילד מספר	שעות	ראות
7	אצווה לכתיבות הטיטור	מה שהמשחקים כבר עשו: 14 קריאות לארבע	יום	פי 3
8	מידה ממספר מכונות	התקרה הנוכחית נמצאה ממכונה אחת	שעות	ידע
9	read replicas	רק אחרי שהקריאות יהיו החצי הגדול	יום	מאוחזר

מה שלא כדאי לעשות עדיין

- לצ'אט עצמו — הילד מחכה לתשובה, ותור לא מחזיר תשובה Redis
- פותר את הבעיה הלא נכונה — compute-לפני שדרוג ה read replicas
- בחצי מהדפים — מעבר חלקי שובר התחברות לכולם PKCE
- עוד אופטימיזציה בשאילתות — הן כבר עולות כמו קריאת שורה בודדת

מה שלא נמדד, ולכן לא נטען כאן

כמה שיחות טיטור במקביל · כמה הרשמות בדקה · עומס אמיתי ממספר מכונות · האם הגיבויים של Supabase ניתנים לשחזור · כמה עולה חודש בעומס מלא.

מקורות: tools/CAPACITY.md · tools/PERFORMANCE.md · SECURITY.md · TODO.md
כלים לבדיקה חוזרת: tools/security_check.py · tools/csp_check.py · tools/browser_check.js